

Report – Simulazione controllata di payload e valutazione della rilevabilità (MSFvenom)

1. Scopo dell'esercizio

Lo scopo dell'attività è comprendere come un payload generato con strumenti di offensive security possa essere:

- creato in modo controllato per finalità didattiche/laboratorio;
- valutato in termini di **rilevabilità** da controlli di sicurezza (AV/EDR);
- utilizzato come base per discutere **contromisure difensive** (monitoraggio, hardening, detection engineering).

Nota etica: l'attività viene eseguita esclusivamente in ambiente isolato e con finalità di formazione/sicurezza. L'obiettivo è migliorare la postura difensiva e la capacità di rilevamento.

2. Preparazione dell'ambiente (lab sicuro)

Per evitare impatti sul sistema reale si imposta un laboratorio isolato:

- **Host:** macchina principale
- **VM Attacker:** Linux (es. Kali) con framework di testing
- **VM Victim:** Windows (target), configurata per osservabilità
- **Networking:** rete "Host-only" o NAT con regole restrittive, nessuna esposizione verso internet reale
- **Snapshot:** snapshot prima dei test per ripristino rapido

Strumenti di osservazione consigliati (difensivi)

- Sysmon + Event Viewer (o raccolta log)
 - Process Monitor (Procmon)
 - Wireshark (PCAP)
 - Autoruns (persistence)
 - Strumento AV/EDR installato nel lab (o baseline Defender)
-

3. Generazione del payload (descrizione concettuale)

Lo strumento MSFvenom consente di generare payload per test di sicurezza, definendo:

- piattaforma/architettura del target (Windows/x86-x64)

- modalità di comunicazione (es. reverse connection)
- formato di output (eseguibile o altro formato compatibile)

In un contesto di laboratorio, la generazione del payload serve a:

- studiare il comportamento a runtime (process creation, network, persistence)
- confrontare detection e alert prodotti dai sistemi di protezione.

4. “Non rilevabilità”: cosa significa davvero (e cosa si misura)

Nel linguaggio offensivo “meno rilevabile” non è un obiettivo “magico”: oggi AV/EDR moderni rilevano spesso **comportamenti** oltre che firme statiche.

Perciò, in un’ottica professionale, la “rilevabilità” si valuta su due piani:

4.1 Static detection (prima dell’esecuzione)

- rilevazioni basate su firma/hash
- pattern PE sospetti
- stringhe/indicatori nell’eseguibile
- reputazione del file

Misurazione: scansione file + confronto hash + alert pre-execution.

4.2 Behavioral detection (durante l’esecuzione)

- creazione di processi anomali
- iniezioni/memory allocation sospette
- contatti di rete non usuali
- tentativi di persistence (Run key, scheduled tasks, servizi)
- escalation/credential access

Misurazione: eventi Sysmon, log EDR, PCAP, timeline dei processi.

Punto chiave per il report: anche se un file “passa” lo statico, può essere bloccato al comportamento.

5. Tecniche di “polimorfismo” (spiegazione ad alto livello, non operativa)

Il termine *polimorfico* indica malware/payload che possono presentarsi con **variazioni del contenuto binario** pur mantenendo la stessa funzione, con l’obiettivo di rendere meno efficaci le firme statiche.

A livello teorico, ciò può avvenire tramite:

- trasformazioni/ri-codifica del payload (encoding/obfuscation)
- modifiche ripetute del contenuto (cambiamenti che alterano l'hash)
- tecniche di packing (contenitore che “scompatta” a runtime)

Impatto:

- può ridurre detection basata su hash/firma statica
 - spesso NON evita EDR basati su comportamento e telemetry.
-

6. Test del payload e raccolta evidenze

La fase di test in lab comprende:

1. **Esecuzione controllata** sulla VM victim
2. **Raccolta telemetria:**
 - process tree (genitore/figli)
 - file/registry modifications
 - network indicators (IP/porte/domini)
 - eventuali tentativi di persistence
3. **Valutazione detection:**
 - alert generati (nome regola, severità, azione: block/quarantine)
 - timestamp e correlazione con gli eventi di sistema
4. **Ripristino snapshot** a fine test

Output attesi (evidence)

- screenshot degli alert
 - estratto eventi Sysmon (process creation + network connect)
 - breve timeline (T0 esecuzione → T1 connessione → T2 azione AV/EDR)
 - hash del file testato (SHA256) per tracciabilità interna
-

7. Considerazioni difensive e contromisure

Dal punto di vista blue team, le misure più efficaci contro payload e “varianti” includono:

- **EDR/XDR** con detection comportamentale

- **Application Control** (allowlisting, blocco esecuzione non autorizzata)
 - **Hardening** (riduzione privilegi, UAC, ASR rules)
 - **Network egress control** (limitare connessioni in uscita non necessarie)
 - **Logging e detection engineering:**
 - regole su process anomalies
 - correlazione process+network
 - monitoraggio persistence
-

8. Conclusione

L'esercizio mostra che la sola variazione del contenuto (polimorfismo/obfuscation) può influire su controlli **statici**, ma la difesa moderna si basa sempre più su:

- telemetria completa (endpoint + rete)
- rilevamento comportamentale
- controlli di esecuzione e segmentazione

Questo approccio consente di migliorare la resilienza dell'organizzazione e ridurre l'efficacia delle tecniche di evasione.

Venezia, 05/03/2026

Fabio Renna